

Practical Report: SMB Enumeration & Information Gathering

Executive Summary

This assessment focused on enumerating the Server Message Block (SMB) service on a target system to identify potential misconfigurations and unauthorized access paths. Using standard enumeration tools, the assessment successfully identified multiple network shares, mapped local users, and confirmed an anonymous login vulnerability that granted interaction with the target's file system.

Theory Section

Server Message Block (SMB) is a network file sharing protocol that operates on ports 139 and 445. In penetration testing, SMB is a prime target for information gathering because legacy or misconfigured implementations often allow "Null Sessions" (anonymous logins).

- **enum4linux:** A wrapper script built around standard Samba tools (smbclient, rpcclient, net, etc.) designed to automate the extraction of information from Windows and Samba hosts, including user lists, share lists, password policies, and OS versioning.
- **smbclient:** An FTP-like client used to access SMB/CIFS resources on servers. It allows testers to interactively list shares, upload/download files, and test access permissions.

Lab Setup

- **Attacker Machine:** 192.168.1.13
- **Target Machine:** 192.168.1.16
- **Target IP Address:** 192.168.1.16
- **Network Environment:** Isolated local host-only lab network.

Step-by-Step Commands

Step 1: Comprehensive SMB Enumeration

```
enum4linux -a 192.168.1.16
```

Explanation: The -a flag runs a full scan (users, shares, OS info, password policies). The output is shown in the Terminal itself.

Step 2: Listing Shares Anonymously

```
smbclient -L //192.168.1.16 -N
```

Explanation: The -L flag requests a list of available shares from the target. The -N flag forces a "No Password" (anonymous) login attempt to see what is exposed without authentication.

Step 3: Accessing a Vulnerable Share

```
smbclient //192.168.1.16/tmp -N
```

Explanation: Connects directly to the tmp share identified in the previous step using a null session, establishing an interactive SMB prompt (smb: \>).

Step 4: Testing Read Permissions

```
smb: \> ls
smb: \> get 4637.jsvc_up
```

Explanation: The ls command lists the directory contents. The get command attempts to download a specific file to test if the anonymous user has read permissions on the target's underlying file system.

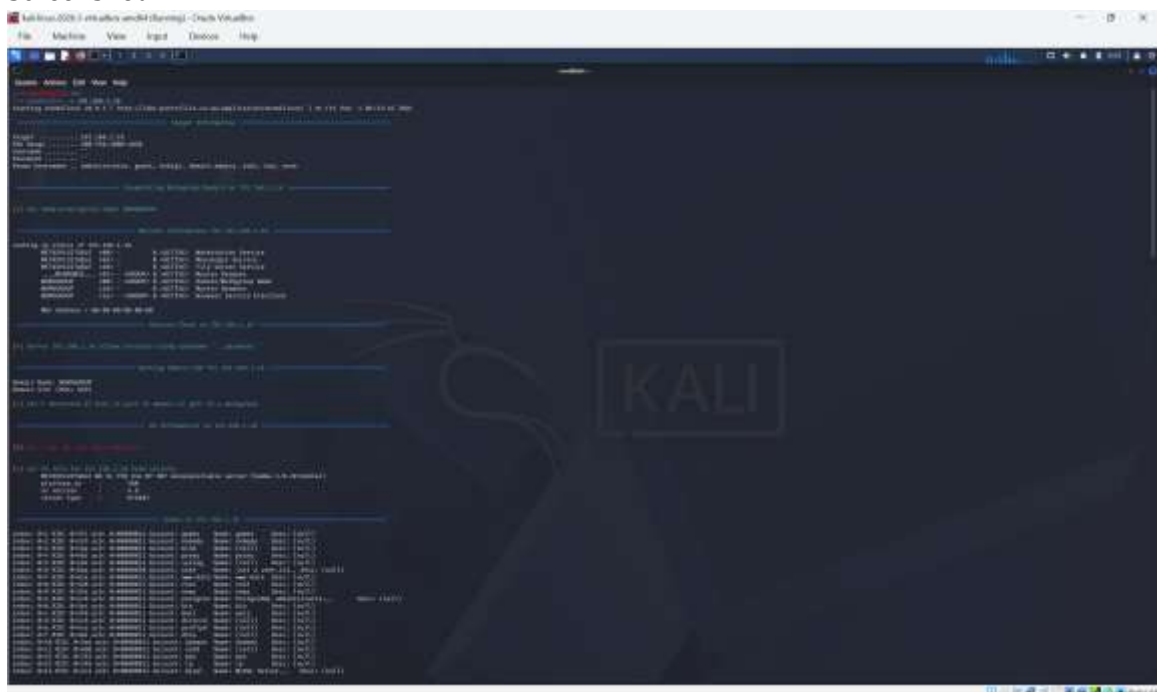
Step 5: Testing Write Permissions

```
# On smbclient prompt:
smb: \> put revshell.py
```

Explanation: Creating a local text file and using the put command tests if the anonymous share allows file uploads, which is a critical finding that could lead to Remote Code Execution (RCE).

Screenshots

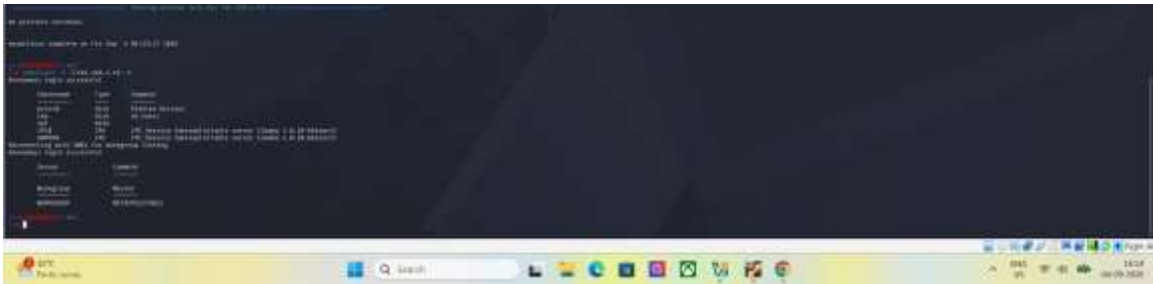
1. Screenshot 1:



2. Screenshot 2:



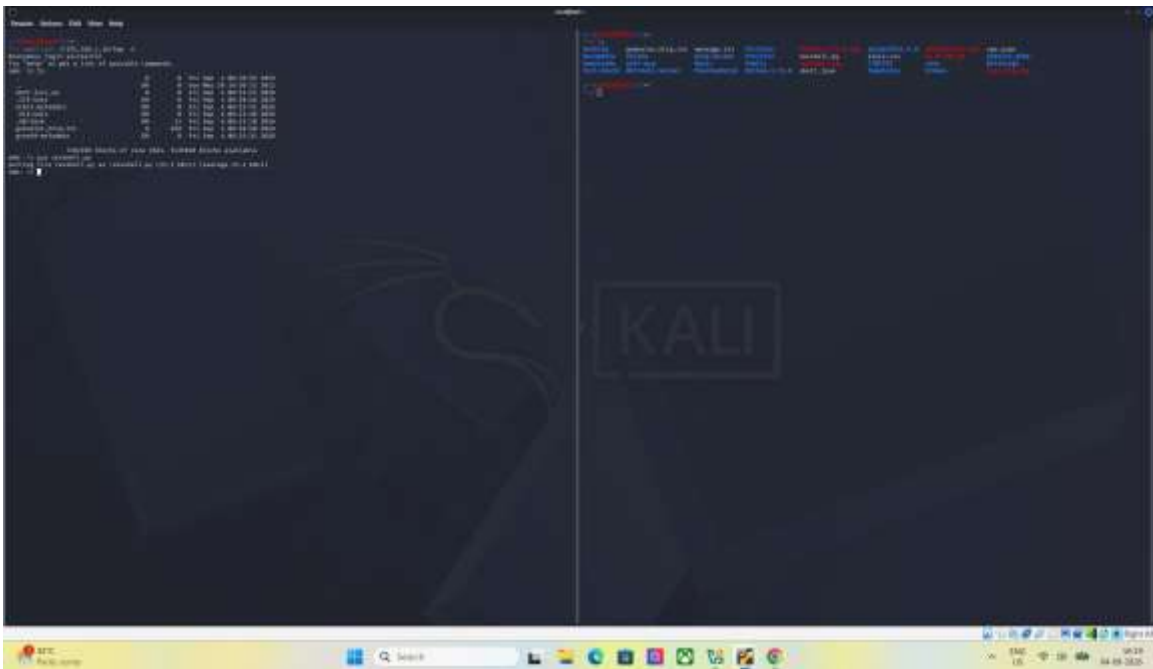
3. Screenshot 3:



4. Screenshot 4:



5. Screenshot 5:



Findings Analysis

6. **Exposed Shares:** The target is broadcasting multiple shares including print\$, tmp, opt, IPC\$, and ADMIN\$.
7. **Anonymous Access:** The tmp share allows unauthenticated (anonymous) connections.
8. **Permission Nuances:** While the SMB share itself allowed anonymous access, the underlying Linux filesystem permissions correctly blocked read access to specific system-owned files (e.g., 4637.jsvc_up returned NT_STATUS_ACCESS_DENIED).
9. **User Mapping:** Local system users (such as msfadmin and root) were successfully mapped, providing a target list for potential brute-force attacks in later phases.

Conclusion

The presence of unauthenticated SMB shares is a significant security risk that provides attackers with internal system intelligence and potential staging grounds for malicious payloads. The most critical lesson learned is the difference between share permissions and filesystem permissions—even if a share is wide open, the OS can still enforce restrictions on individual files.

Recommendations for Remediation:

- Disable 'Null Sessions' and anonymous access in the Samba configuration (smb.conf) by setting restrict anonymous = 2.
- Enforce strong authentication for all network shares.
- Ensure that any shares required for legacy purposes are set to read-only and do not contain sensitive system data or user information.